

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce

Session : Semester A 2010/11

Time allowed : Two hours

This paper has SIX pages (including this cover page).

1. This paper consists of 7 questions.
 2. Answer ALL SEVEN questions.
 3. Total: 100 points
 4. This is a close-book examination: students should not bring any book, lecture or tutorial note; problem set solution or any other related paper or printout
 5. Calculators: only HKEA approved ones
-

NOT TO BE TAKEN AWAY

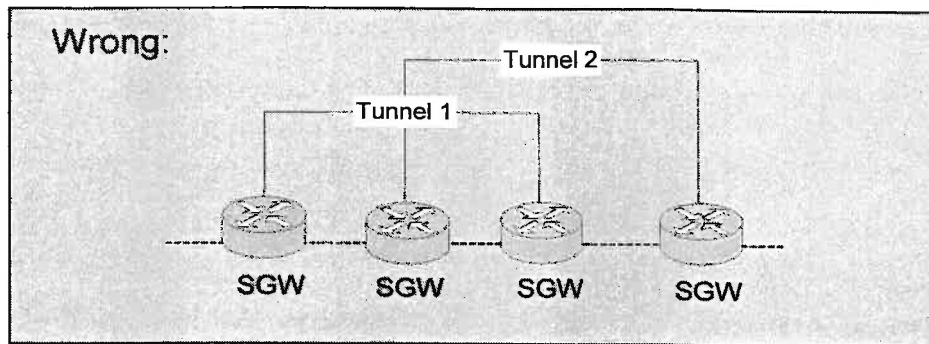
**NOT TO BE TAKEN
AWAY BUT
FORWARDED TO LIB**

Remark: Give concise reasons and show key steps in each problem. Keep your answers and reasons brief and right-to-the-point.

1. Network Security and Wireless Security (11 points)

(a) (6 points)

The following tunneling configuration is invalid.



Show the changes of IPSec encapsulations of a packet when it travels from the leftmost SGW to the third SGW from the left. Assume that the packet is initiated from a machine connecting to the leftmost SGW. The IP addresses of the 4 SGWs are (1.1.1.1, 2.2.2.1), (3.3.3.1, 4.4.4.1), (5.5.5.1, 6.6.6.1), and (7.7.7.1, 8.8.8.1), respectively, from left to right. Assume that the packet sender's IP address is 1.1.1.23 and the destination's IP address is 8.8.8.72.

(b) (5 points)

Suppose in a particular implementation of 802.11 WEP, the three-byte initialization vector (IV) increases by 1 each time after encrypting one packet. Hence for every 2^{24} packets, the IV value will wrap around. Suppose the first packet and the $2^{24}+1$ -th packet are encrypted under the same key sequence (and the same IV value). Let C' and C'' be the corresponding ciphertexts and M' and M'' be the corresponding messages. Given

$C' = 11001011$

$C'' = 01100101$

$M' = 10101010$

Compute M'' .

2. Computer Security (10 points)

(a) (5 points)

Assume that passwords are selected from eight-character combinations of 62 alphabetic characters. Assume that an adversary is able to attempt passwords at a speed of one million passwords per second. Assuming no feedback is given to the adversary until each attempt has been completed, what is the expected time to discover the correct password? Give your answer in number of days.

(b) (5 points)

For a similar question to part (a) above, suppose that feedback is given to the adversary flagging an error as each incorrect character is entered, what is the expected time to discover the correct password? Give your answer in number of microseconds.

3 Symmetric Key Cryptography (11 points)

(a) (5 points)

Given a pair of plaintext P and ciphertext C encrypted under a DES key, in the worst case, how long does an attacker have to try for finding a key K such that $C = \text{DES}(K, P)$ which represents the DES encryption of P under key K ? Assume that the attacker can perform 10^{13} encryptions per second. Give your answer to the nearest hours.

(b) (6 points)

If AES is used, for each of the applications below, identify the most suitable operation mode and explain why the other two operation modes are not desirable. Operation modes to choose from are ECB, CBC and CTR.

(1) Building a Message Authentication Code (MAC);

(2) Encrypting a hard-disk where individual data blocks are updated arbitrarily;

(3) Encrypting an 80-bit session key and transmitting it over a low bandwidth communication channel.

4. Public Key Encryption (24 points)

(a) (4 points)

List out all the eight elements in a set G such that $(G, * \bmod 15)$ forms a group.

(b) (6 points)

Let the RSA public modulus $n = pq = 47 \cdot 71 = 3337$. Let the RSA public exponent $e = 79$. Find the corresponding RSA private exponent d .

(c) (4 points)

For each of the algorithms below, name the underlying mathematical assumption that the algorithm's security is relying on.

(1) ElGamal Encryption

(2) RSA Encryption

(d) (6 points)

In an RSA cryptosystem, suppose we are given a public key (n, e) where $e = 3$ and $n \equiv 2 \pmod{3}$.(1) What are the values of $p \bmod 3$ and $q \bmod 3$?

(2) Can you tell what goes wrong with this RSA system?

(e) (4 points)

Consider an RSA system with $p=7$, $q=11$ and the public modulus $n = pq$. There are some messages M such that $M^7 \equiv M \pmod{n}$. They are called fixed plaintexts. Find four of them. Note that each of the messages should be a positive nonzero integer smaller than n .

5. Hash Function and Message Authentication Code (9 points)

(a) (5 points)

Use at most two sentences to define the collision resistance security requirement of SHA-1. Find out the expected number of messages that a brute-force attacker has to try in order to break the collision resistance of SHA-1. Represent your result in 2's power.

(b) (4 points)

Draw a diagram to show how an AES-CBC based MAC works. In your diagram, use $M = m_1 \parallel m_2 \parallel m_3$ to represent three blocks of message, T to represent the MAC tag and K to represent the key. The symbol ' $\parallel$ ' represents binary string concatenation.

6. Authentication and Key Exchange (18 points)

(a) (10 points)

Let p be a prime and g a generator of Z_p^* . Describe the Diffie-Hellman Key Exchange protocol running between Alice and Bob. In your answer, use K to denote a session key. Then describe a three-move public key encryption based key exchange protocol with perfect forward secrecy. Use $\{M\}_{\text{Bob}}$ to denote a public key encryption of message M under Bob's public key.

(b) (8 points)

Suppose that Alice and Bob share a long-term symmetric key K and they do not have any public key. Describe four different symmetric key based challenge-response protocols, each of them allows Bob to authenticate Alice.

7. SSL (17 points)

(a) (5 points)

To improve the RSA encryption performance in SSL, suppose that a web server chooses its public key (n, e) such that e is small and $n = (2p+1)(2q+1)$ where p and q are prime and $(2p+1)$ and $(2q+1)$ are also prime. Suppose that n is 1024 bits long and factoring n is assumed to be difficult.

- (1) Can the public exponent e be set to p ? Why?
- (2) For efficiency, suppose e is set to 3. If all the messages to be encrypted using this public key are at most 40 bytes (or 320 bits) long, explain why this RSA cryptosystem is insecure.

(b) (6 points)

Let (n, e) be the RSA public key and d the RSA private key. To protect every single bit of a message m , SSL protocol encrypts m using an algorithm similar to the following.

- (1) Pick a random number r
- (2) Compute the ciphertext $c = (m \oplus G(r) \parallel r \oplus H(m \oplus G(r)))^e \bmod n$

where G and H are hash functions and ' $\parallel$ ' denotes binary string concatenation. Describe the decryption algorithm. (Hint: there are three steps.)

(c) (6 points)

Following part (a) above, if n is 1024 bits long, r is 256 bits long, find out the maximum length of m that this SSL encryption method supports. Also find out the output length of G and H .